

Social Engineering Attack

Credential Harvesting – Walkthrough Report

1. Executive Summary

This report documents a step-by-step walkthrough of a targeted Social Engineering Attack simulation, specifically a Credential Harvesting attack that serves as a precursor to full account compromise. By masquerading as an internal IT department, a simulated malicious actor was able to deceive a target user into submitting their Google Account credentials to an attacker-controlled phishing page.

The primary goal of this walkthrough is to demonstrate how easily sensitive administrative or executive accounts can be compromised through social engineering and technical spoofing — and to highlight what defenders should look for at each stage.

2. Attack Description

The attack leveraged the Social-Engineer Toolkit (SET), an open-source penetration testing framework designed for social engineering scenarios. SET was used to:

- Clone a legitimate Google Account login portal pixel-for-pixel.
- Host the cloned site on an attacker-controlled local IP address (10.45.225.79).
- Intercept and log all form submissions (username + password) in plaintext.

3. Step-by-Step Walkthrough

The following section walks through each phase of the attack from initial setup to data capture.

Step 1: Environment Setup

A Kali Linux machine was prepared with the Social-Engineer Toolkit (SET) pre-installed. SET is included by default in Kali Linux distributions and is commonly used in authorized red-team engagements.

Step 2: Launching the Credential Harvester

SET was launched from the terminal. The attacker navigated to:

- Social-Engineering Attacks
- Website Attack Vectors
- Credential Harvester Attack Method
- Web Templates → Google

SET then cloned Google's login page and hosted it locally on port 80. The attacker's machine IP (10.45.225.79) became the phishing URL endpoint.

Step 3: Crafting & Delivering the Phishing Lure

A phishing email was simulated, impersonating the internal IT Department. The email contained:

- **Spoofed Sender:** An email address appearing to come from an IT helpdesk or administrator.
- **Urgent Pretext:** A message warning the target about suspicious account activity and requesting immediate login verification.
- **Malicious Link:** A hyperlink pointing to <http://10.45.225.79> — the attacker-controlled clone of the Google login page.

Step 4: Victim Interaction (User Lands on Phishing Page)

The target user clicked the link in the phishing email and was directed to the cloned Google Sign-In page hosted at <http://10.45.225.79>. The page appeared visually identical to the real Google login portal.

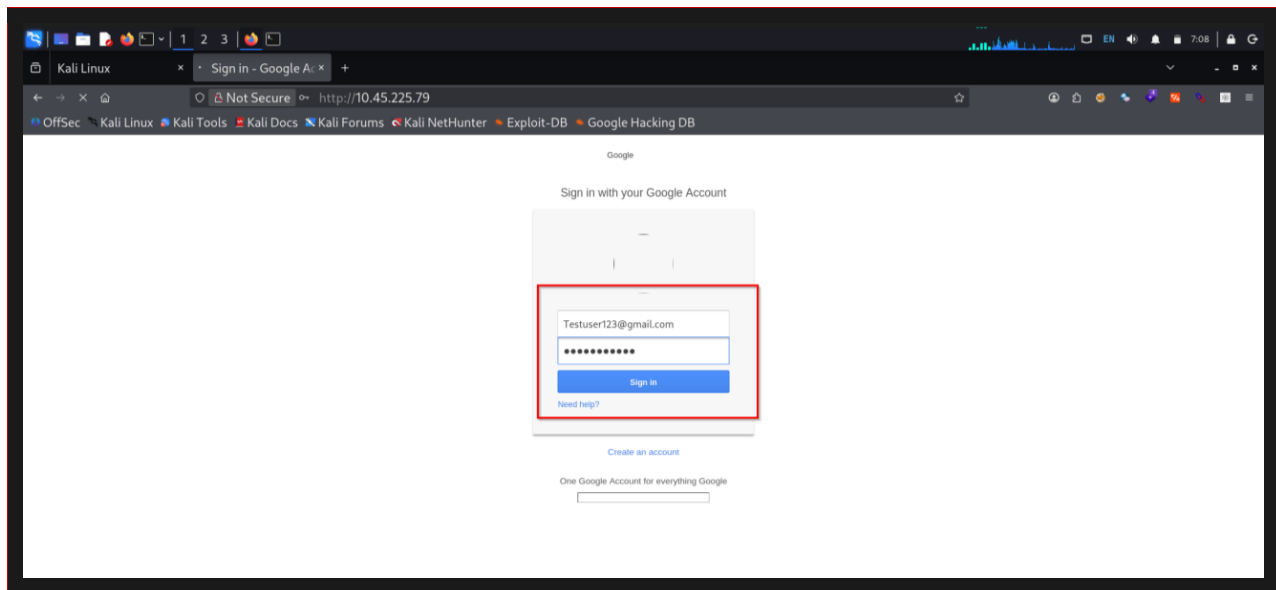
The only visible indicator of compromise was the browser's address bar showing "Not Secure" (HTTP instead of HTTPS) and the IP address instead of accounts.google.com — a detail most untrained users overlook.

The target proceeded to enter their test credentials:

- **Email:** testuser123@gmail.com
- **Password:** Testuser000

POC: Cloned Google Login Page Served to Victim

The victim sees a pixel-perfect Google Sign-In form. The browser shows the attacker's IP (<http://10.45.225.79>) and marks the connection as "Not Secure".



Step: Credential Capture (Data Intercepted by SET)

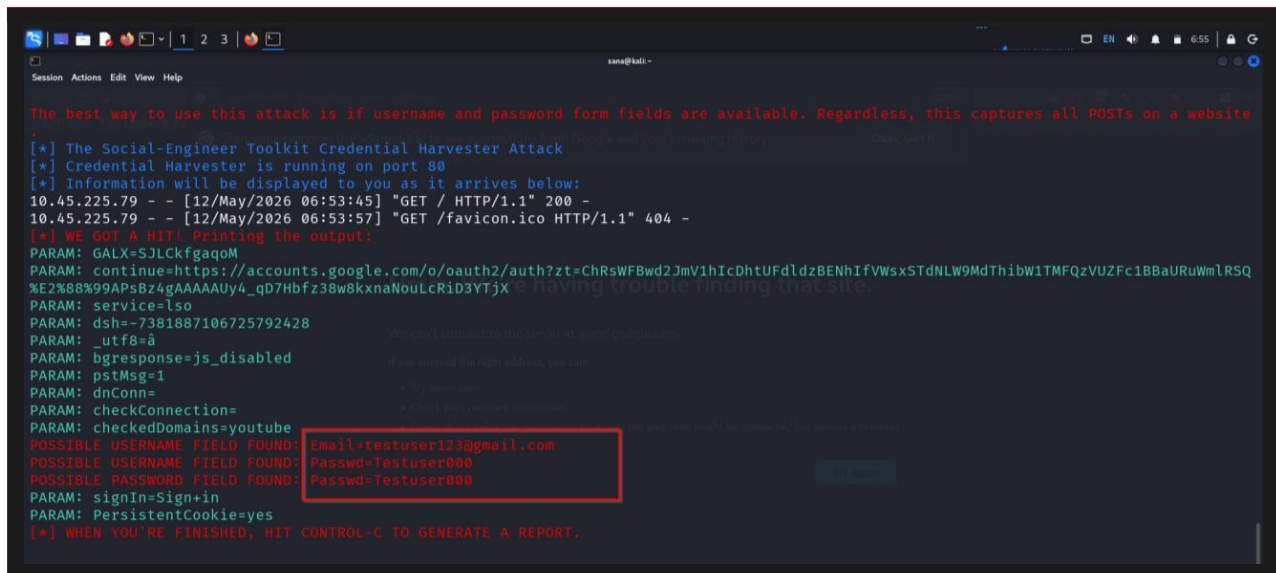
When the victim clicked "Sign In", the browser submitted a POST request to the attacker's server. SET's Credential Harvester intercepted this request and logged all submitted form parameters in plaintext directly to the Kali terminal.

Key parameters logged included:

- **Email (Username):** testuser123@gmail.com
- **Passwd (Password):** Testuser000 — captured in cleartext
- **PersistentCookie=yes:** Indicates the user had "Stay signed in" checked — enabling session hijacking via cookie theft
- **Sign=Sign In:** Confirms the form was submitted by the user
-

POC: SET Terminal Output Showing Captured Credentials

The Kali terminal clearly displays the intercepted POST parameters, including the victim's email, password in plaintext, and session persistence flag.



```
Session Actions Edit View Help

The best way to use this attack is if username and password form fields are available. Regardless, this captures all POSTs on a website.

[*] The Social-Engineer Toolkit Credential Harvester Attack
[*] Credential Harvester is running on port 80
[*] Information will be displayed to you as it arrives below:
10.45.225.79 - - [12/May/2026 06:53:45] "GET / HTTP/1.1" 200 -
10.45.225.79 - - [12/May/2026 06:53:57] "GET /favicon.ico HTTP/1.1" 404 -
[*] WE GOT A HIT! Printing the output:
PARAM: GALX=SJLckfgaqoM
PARAM: continue=https://accounts.google.com/o/oauth2/auth?zt=ChRsWFBwd2JmV1hIcDhtUFdlzBENhIfVWsxSTdNLW9MdThibW1TMFQzVUZFc1BBaURuWmlRSQ
%E2%88%99APsBz4gAAAAUy4_qD7Hbfz38w8kxnaNouLcRiD3YTjX
PARAM: service=lsso
PARAM: dsh=-7381887106725792428
PARAM: _utf8=a
PARAM: bgresponse=js_disabled
PARAM: pstMsg=1
PARAM: dnConn=
PARAM: checkConnection=
PARAM: checkedDomains=youtube
POSSIBLE USERNAME FIELD FOUND: Email=testuser123@gmail.com
POSSIBLE USERNAME FIELD FOUND: Passwd=Testuser000
POSSIBLE PASSWORD FIELD FOUND: Passwd=Testuser000
PARAM: signIn=Sign+in
PARAM: PersistentCookie=yes
[*] WHEN YOU'RE FINISHED, HIT CONTROL-C TO GENERATE A REPORT.
```

4. Impact Assessment

- **Complete Account Takeover:** The attacker gains full access to the victim's Gmail, Google Drive, Google Docs, and all integrated corporate services.
- **Session Hijacking:** The PersistentCookie=yes flag indicates the attacker can steal and replay the session cookie, maintaining long-term access without needing the password again.
- **Data Breach:** Unauthorized access to an executive's email enables exfiltration of confidential strategies, financial data, and sensitive internal communications.
- **Lateral Movement:** With a compromised Google account, attackers may pivot to SSO-connected services, internal wikis, and cloud infrastructure.

5. Severity: Critical

CRITICAL

Bypasses standard password-only protections. Enables immediate, high-privilege access to executive-level accounts and corporate infrastructure without triggering traditional security controls.

6. Recommendations

- **Hardware-Based MFA (FIDO2/WebAuthn):** Mandate the use of physical security keys (e.g., YubiKeys) for all executive and admin accounts. FIDO2 keys are phishing-resistant — they verify the website's domain before responding, so a cloned site cannot trigger authentication.

- **Advanced Phishing Protection:** Deploy email security gateways with real-time URL inspection, domain spoofing detection, and DMARC/DKIM/SPF enforcement to block phishing lures before they reach inboxes.
 - **Certificate Pinning & Browser Policies:** Enforce HTTPS-only browsing via managed browser policies. Browsers should warn or block HTTP sites where credentials may be entered. Train users to verify the padlock and the URL before logging in.
 - **Session Management Controls:** Configure shorter session timeouts and implement IP-binding for session cookies. This limits the window of opportunity for a hijacked session to be abused.
 - **Security Awareness Training:** Conduct regular phishing simulation exercises so employees recognize urgency-based lures, spoofed sender addresses, and suspicious login pages — especially those served over HTTP from IP addresses.
-